



Domain 2: IR, BC & DR Concepts

Incident Terminology:

- **Breach** → Unauthorised access / disclosure of sensitive data.
- **Event** → An observable occurrence within a system.
- **Exploit** → Code / method used to take advantage of vulnerabilities.
- **Incident** → Event compromising CIA.
- **Intrusion** → Unauthorised access attempt or success by intruder.
- **Vulnerability** → Weakness in systems / processes that can be exploited.
- **Zero-day** → Unknown vulnerability exploited before being patched.
- **Threat** → Potential danger exploitable vulnerabilities.

The Goal Incident Response:

- Priority of IR is to protect life, health and safety. when any decision related to priorities is to be made, always choose safety first.
- Primary goal of **incident management is to be prepared**. (Policy & Response plan) The term "Crisis management" is used to describe this process.
- Reduce the impact of an incident. IR planning is subset of greater discipline of Business continuity management (BCM)

Components of Incident Response Plan:

IRP - Structured approach designed to help organizations detect, respond to, and recover from security incidents effectively.

1. Preparation

- Develop a policy approved by management.
- Identify critical data and systems for any single points of failure. (SPOFs)
- Train staff for IR.
- Implement an Incident Response team.
- Practice Incident identification. (First Response)
- Identify roles and responsibilities.
- Plan the coordination of communication between stakeholders.
- Consider primary method of communication may not be available

2. Detection & Analysis

- Monitor all possible attack vectors.
- Analyse the incident using known data and threat intelligence.
- Prioritize IR.
- Standardize Incident document.

3. Containment, Eradication and Recovery

- Gather evidence.
- Choose an appropriate containment strategy.
- Identify the attacker.
- Isolate the attack.

4. Post-Incident Activity

- Identify the evidence that may need to be retained.
- Document lesson learned.

Models for Incident Response Team (IRT):

- **Leveraged IRT:** A part-time team where members have other day jobs and are trained to help with security incidents as needed.
- **Dedicated IRT:** A full-time team of specialists whose only job is to handle security incidents, available 24/7.
- **Hybrid IRT:** A combination model with a core full-time team that gets help from other department experts when necessary.

Incident Response Team:

- Representative(s) of senior management
 - Information security professionals
 - Legal representatives
 - Public affairs / communication representatives
 - Engineering representatives (System & Network)
- Specialized teams: CIRTs & CSIRTs (Computer Security Incident Response Teams)

Their four primary responsibilities:

1. Determine the amount and scope of damage caused by the incident.
2. Determine whether any confidential information was compromised during Incident.
3. Implement any necessary recovery procedures to restore security and recover from incident - related damage.
4. Supervise the implementation of any additional security measures necessary to improve security and prevent recurrence of the incident.

Business Continuity in the workspace:

Redbook - All the produres are outlined in that document. (Hardcopy)

The Goal and Importance of Business Continuity:

- Communication and contact methods - multiple contact methods, critical contact numbers.
- Activating BCP - call appropriate indivisuals, priorities, authorisation.
- Handling cyberattacks and communication failure. (US - Military-grade networks used for emergency communication)
- Emergency contact structure (Phone tree)
- Checklist and procedures

The Goal of Disaster Recovery:

See the business restored to full last-known reliable operations. (DRP guides until reach the goal)

Components of Business Continuity Process:

- List of BCP members, including contact members, including multiple contact methods and backup members.
- Immediate response procedures and checklists.
- Notification systems and call trees for alternating personnel that the BCP is being enacted.
- Guidance for management, including designation of authority for specific managers.
- How, when to enact plan.
- Contact numbers for critical members of the supply chain.

Business Continuity in Action:

BIA - Business Impact Analysis

Understand potential damage from an Incident to prioritise defenses and recovery plans.

Business Continuity Process:

1. Develop the contingency planning policy.
2. Conduct BIA.
3. Identify preventative controls.
4. Create contingency strategies.
5. Develop Information System contingency plan.
6. Ensure plan testing, training and exercises.
7. Ensure plan maintainance.

Components of Disaster Recovery Plan:

- Executive summary providing a high-level overview of the plan.
- Department-specific plans.
- Technical guides for IT personnel responsible for implementing and maintaining critical backup systems.
- Full copies for the plan for critical disaster recovery team members.
- Checklist for certain individuals:
 - Critical DR team members will have checklist to help guide their actions amid the chaotic atmosphere of a disaster.
 - IT personnel will have technical guides helping them to get the alternate site up and running.
 - Managers and public relations personnel will have simple-to-follow, high level documents to help them communicate the issue accurately without requiring input from team members who are busy working on the recovery.